TrustArc NYMITY

PRIVACY AND DATA GOVERNANCE ACCOUNTABILITY FRAMEWORK

BUILD IMPLEMENT DEMONSTRATE

Aligning privacy controls and privacy management activities across our Privacy and Data Governance Accountability Frameworks

BUILD

Design, establish, and manage a program to ensure effective governance, risk management, policies, processes, and accountability.

PMC 1
- Assign responsibility for data privacy to an individual (e.g. Privacy Officer, General Counsel, CPO, CISO, EU Representative).
- Engage senior management in data privacy (e.g. at the Board of Directors, Executive Committee).
- Appoint a Data Protection Officer (DPO) in an independent oversight role.
- Assign responsibility for data privacy throughout the organization (e.g. privacy network).
- Maintain roles and responsibilities for individuals responsible for data privacy (e.g. job descriptions).
- Conduct regular communication between the privacy office, privacy network, and others responsible/accountable for data privacy.
- Engage stakeholders throughout the organization on data privacy matters (e.g. information security, marketing, etc.).
- Conduct an Enterprise Privacy Risk Assessment.
- Integrate data privacy into business risk assessments/reporting.
- Maintain a Privacy Strategy.
- Maintain a privacy program charter/mission statement.
- Require employees to acknowledge and agree to adhere to the data privacy policies.

PMC 2
- Maintain an inventory of personal data and/or processing activities.
- Classify personal data by type (e.g. sensitive, confidential, public).
- Maintain documentation of data flows e.g. between systems, between processes, between countries).

PMC 3
- Maintain a data privacy policy.
- Maintain an employee data privacy policy.

PMC 4
- Maintain policies/procedures to review processing conducted wholly or partially by automated means.

PMC 5
- Conduct privacy training.
- Conduct privacy training reflecting job specific content.
- Conduct regular refresher training.
- Incorporate data privacy into operational training (e.g. HR, marketing, call center).
- Deliver training/awareness in response to timely issues/topics.
- Provide a repository of privacy information (e.g. an internal data privacy intranet).
- Maintain privacy awareness material (e.g. posters and videos).
- Conduct privacy awareness events (e.g. an annual data privacy day/week).
- Enforce the requirement to complete privacy training.
- Provide ongoing education and training for the Privacy Office and/or DPOs.
- Maintain qualifications for individuals responsible for data privacy, including certifications.

PMC 6
- Maintain an acceptable use of information resources policy.

PMC 7
- Maintain data privacy requirements for third parties (e.g. clients, vendors, processors, affiliates).
- Conduct due diligence on third party data sources.
- Maintain a vendor data privacy risk assessment process.
- Maintain a policy governing use of cloud providers.
- Maintain procedures to address instances of non-compliance with contracts and agreements.

PMC 9
- Maintain procedures to address complaints.
- Maintain procedures to respond to requests for access to personal data.
- Maintain procedures to respond to requests and/or provide a mechanism for individuals to update or correct their personal data.
- Maintain procedures to respond to requests to opt-out of, restrict, or object to processing.
- Maintain procedures to respond to requests for information.
- Maintain procedures to respond to requests for data portability.
- Maintain procedures to respond to requests to be forgotten or for erasure of data.
- Maintain Frequently Asked Questions to respond to queries from individuals.
- Investigate root causes of data privacy complaints.

PMC 10
- Integrate Privacy by Design into data processing operations.
- Maintain PIA/DPIA guidelines and templates.
- Conduct PIAs/DPIAs for new programs, systems, and/or processes.
- Conduct PIAs/DPIAs s for changes to existing programs, systems, or processes.
- Engage external stakeholders (e.g. individuals, privacy advocates) as part of the PIA/DPIA process.
- Track and address data protection issues identified during PIAs/DPIAs.

PMC 11
- Maintain a data privacy incident/breach response plan.
- Maintain a log to track data privacy incidents/breaches.
- Conduct periodic testing of data privacy incident/breach plan.
- Engage a breach response remediation provider.
- Engage a forensic investigation team.
- Obtain data privacy breach insurance coverage.

PMC 13
- Identify ongoing privacy compliance requirements (e.g. law, case law, codes, etc.)
- Maintain subscriptions to compliance reporting service/law firm updates to stay informed of new developments.
- Attend/participate in privacy conferences, industry association, or think-tank events.
- Record/report on the tracking of new laws, regulations, amendments, or other rule sources.
- Seek legal opinions regarding recent developments in law.
- Identify and manage conflicts in law.
- Document decisions around new requirements, including their implementation or any rationale behind decisions not to implement changes.

TrustArc NYMITY

ACTIVITIES BASED

PRIVACY AND DATA GOVERNANCE ACCOUNTABILITY FRAMEWORK

BUILD IMPLEMENT DEMONSTRATE

IMPLEMENT

Define data needs, identify data processing risks, ensure the data processing is lawful, manage data flows and third parties, address individual rights, provide data security, data quality, and transparency.

PMC 7
- Maintain procedures to execute contracts or agreements with all processors
- Conduct due diligence around the data privacy and security posture of potential vendors/processors
- Review long-term contracts for new or evolving data privacy risks

PMC 8
- Maintain a data privacy notice
- Provide data privacy notice at all points where personal data is collected
- Provide notice by means of on-location signage, posters
- Provide notice in marketing communications (e.g. emails, flyers, offers)
- Provide notice in contracts and terms
- Maintain scripts for use by employees to explain or provide the data privacy notice

PMC 9
- Implement procedures to respond to requests for access to personal data
- Implement procedures to respond to requests and/or provide a mechanism for individuals to update or correct their personal data
- Implement procedures to respond to requests to opt-out of, restrict, or object to processing
- Implement procedures to respond to requests for information
- Implement procedures to respond to requests for data portability
- Implement procedures to respond to requests to be forgotten or for erasure of data

PMC 11
- Maintain a breach notification (to affected individuals) and reporting (to regulators, credit agencies, law enforcement) protocol

PMC 2
- Maintain documentation of the transfer mechanism used for cross-border data flows (e.g., model clauses, BCRs, regulator approvals).
- Use contracts as a data transfer mechanism (e.g. Standard Contractual Clauses).
- Use adequacy or one of the derogations (e.g. consent, performance of a contract, public interest) as a data transfer mechanism.

PMC 3
- Document legal basis for processing personal data.

PMC 4
- Maintain policies/procedures for collection and use of sensitive personal data (including biometric data).
- Maintain policies/procedures for collection and use of children's and minors' personal data.
- Maintain policies/procedures for maintaining data quality.
- Maintain policies/procedures for the de-identification of personal data.
- Maintain policies/procedures to review processing conducted wholly or partially by automated means.
- Maintain policies/procedures for secondary uses of personal data.
- Maintain policies/procedures for obtaining valid consent.
- Maintain policies/procedures for secure destruction of personal data.
- Integrate data privacy into use of cookies and tracking mechanisms.
- Integrate data privacy into records retention practices enforcement purposes.
- Integrate data privacy into research practices (e.g. scientific and historical research).
- Integrate data privacy into direct marketing practices.
- Integrate data privacy into email marketing practices.
- Integrate data privacy into telemarketing practices.
- Integrate data privacy into digital advertising practices (e.g. online, mobile).
- Integrate data privacy into hiring practices.
- Integrate data privacy into the organization's use of social media.
- Integrate data privacy into Bring Your Own Device (BYOD) policies/procedures.
- Integrate data privacy into health & safety practices.
- Integrate data privacy into interactions with works councils.
- Integrate data privacy into practices for monitoring employees.
- Integrate data privacy into use of CCTV/video surveillance.
- Integrate data privacy into use of geo-location (tracking and/or location) devices.
- Integrate data privacy into policies/procedures regarding access to employees' company email accounts.
- Integrate data privacy into e-discovery practices.
- Integrate data privacy into conducting internal investigations.
- Integrate data privacy into practices for disclosure to and for law enforcement purposes.

PMC 6
- Integrate data privacy risk into security risk assessments.
- Integrate data privacy into an information security policy.
- Maintain technical security measures (e.g. intrusion detection, firewalls, monitoring).
- Maintain measures to encrypt personal data.
- Maintain procedures to restrict access to personal data (e.g. role-based access, segregation of duties).
- Integrate data privacy into a corporate security policy (protection of physical premises and hard assets).
- Maintain human resource security measures (e.g. pre-screening, performance appraisals).
- Integrate data privacy into business continuity plans.
- Maintain a data-loss prevention strategy.

DEMONSTRATE

Monitor, evaluate, and report on compliance, control effectiveness, risk, and maturity.

PMC 1
- Report to internal stakeholders on the status of privacy management (e.g. board of directors, management).
- Report to external stakeholders on the status of privacy management (e.g. regulators, third-parties, clients).

PMC 2
- Use Binding Corporate Rules as a data transfer mechanism.
- Use APEC Cross Border Privacy Rules as a data transfer mechanism.
- Use Privacy Shield as a data transfer mechanism.
- Obtain regulator approval for data processing (where prior approval is required).
- Register databases with regulators (where registration is required).
- Use regulator approval as a data transfer mechanism.

PMC 3
- Maintain an organizational code of conduct that includes privacy
- Integrate ethics into data processing (Codes of Conduct, policies, and other measures).

PMC 5
- Measure participation in data privacy training activities (e.g. number of participants, scoring).

PMC 6
- Conduct regular testing of data security posture
- Maintain a security certification (e.g. ISO).

PMC 7
- Conduct due diligence around the data privacy and security posture of existing vendors/processors.

PMC 8
- Maintain a privacy seal or trustmark on the website to increase customer trust.

PMC 9
- Monitor and report metrics for data privacy complaints (e.g. number, root cause).

PMC 10
- Report PIA/DPIA analysis and results to regulators (where required) and external stakeholders (if appropriate).

PMC 11
- Maintain a breach notification (to affected individuals) and reporting (to regulators, credit agencies, law enforcement) protocol.
- Monitor and report data privacy incident/breach metrics (e.g. nature of breach, risk, root cause).

PMC 12
- Conduct self-assessments of privacy management.
- Conduct Internal Audits of the privacy program (i.e. operational audit of the Privacy Office).
- Conduct ad-hoc walk-throughs.
- Conduct ad-hoc assessments based on external events, such as complaints/breaches.
- Engage a third party to conduct audits/assessments.
- Monitor and report privacy management metrics.
- Maintain documentation as evidence to demonstrate compliance and/or accountability.
- Maintain certifications, accreditations, or data protection seals for demonstrating compliance to regulators.

Nymity Privacy Management Accountability Framework™

Privacy Management Categories

PMC 1 - Maintain Governance Structure
PMC 2 - Maintain Personal Data Inventory and Data Transfer Mechanisms
PMC 3 - Maintain Internal Data Privacy Policy
PMC 4 - Embed Data Privacy into Operations
PMC 5 - Maintain Training and Awareness Program
PMC 6 - Manage Information Security Risk
PMC 7 - Manage Third Party Risk
PMC 8 - Maintain Notices
PMC 9 - Respond to Requests and Complaints from Individuals
PMC 10 - Monitor for New Operational Practices
PMC 11 - Maintain Data Privacy Breach Management Program
PMC 12 - Monitor Data Handling Practices
PMC 13 - Track External Criteria

© 2021 TrustArc Inc. All rights reserved.

CONTROLS BASED

Privacy and Data Governance Accountability Frameworks

BUILD

Design, establish, and manage a program to ensure effective governance, risk management, policies, processes, and accountability. 6 Standards.

FS1 **Integrated Governance**
Identify stakeholders. Establish program leadership and governance. Define program mission, vision, and goals.

FS2 **Risk Assessment**
Identify, assess, and classify data-related strategic, operational, legal, compliance, and financial risks.

FS3 **Resource Allocation**
Establish budgets. Define roles and responsibilities. Assign personnel.

FS4 **Policies and Standards**
Develop policies, procedures, and guidelines to define and deploy effective and sustainable governance and controls for managing data-related risks.

FS5 **Processes**
Establish, manage, measure, and continually improve processes for PIAs, vendor assessments, incident management and breach notification, complaint handling, and individual rights management.

FS6 **Awareness and Training**
Communicate expectations. Provide general and contextual training.

IMPLEMENT

Define data needs, identify data processing risks, ensure the data processing is lawful, manage data flows and third parties, address individual rights, provide data security, data quality, and transparency. 8 Standards.

FS7 **Data Necessity**
Optimize data value by collecting and retaining only the data necessary for strategic goals. Leverage anonymization, de-identification, pseudonymization, and coding to mitigate data storage-related risks.

FS8 **Use, Retention, and Disposal**
Ensure data is used only as legally permissible and solely for purposes that are relevant to and compatible with the purposes for which it was collected.

FS9 **Disclosure to Third Parties and Onward Transfer**
Preserve the framework standards and protections for data when it is transferred to third-party organizations and/or across country borders.

FS10 **Choice and Consent**
Enable individuals to choose whether personal data about them is processed. Obtain and document prior permission where necessary and appropriate, and enable individual to opt-out of ongoing processing.

FS11 **Access and Individual Rights**
Enable individuals to access information about themselves, to amend, correct, and as appropriate, delete information that is inaccurate, incomplete, or outdated.

FS12 **Data Integrity and Quality**
Assure that data is kept sufficiently accurate, complete, relevant, and current consistent with its intended use.

FS13 **Security**
Protect data from loss, misuse, and unauthorized access, disclosure, alteration, or destruction.

FS14 **Transparency**
Inform individuals about the ways in which data about them are processed and how to exercise their data-related rights.

DEMONSTRATE

Monitor, evaluate, and report on compliance, control effectiveness, risk, and maturity. 2 Standards.

FS15 **Monitoring and Assurance**
Evaluate and audit effectiveness of controls and risk-mitigation initiatives.

FS16 **Reporting and Certification**
Demonstrate the effectiveness of your program and controls to management, the Board of Directors, employees, customers, regulators, and the public.

BUILD

Design, establish, and manage a program to ensure effective governance, risk management, policies, processes, and accountability.

6 Standards

FS1 **Integrated Governance**
Identify stakeholders. Establish program leadership and governance. Define program mission, vision, and goals.

FS2 **Risk Assessment**
Identify, assess, and classify data-related strategic, operational, legal, compliance, and financial risks.

FS3 **Resource Allocation**
Establish budgets. Define roles and responsibilities. Assign personnel.

FS4 **Policies and Standards**
Develop policies, procedures, and guidelines to define and deploy effective and sustainable governance and controls for managing data-related risks.

FS5 **Processes**
Establish, manage, measure, and continually improve processes for PIAs, vendor assessments, incident management and breach notification, complaint handling, and individual rights management.

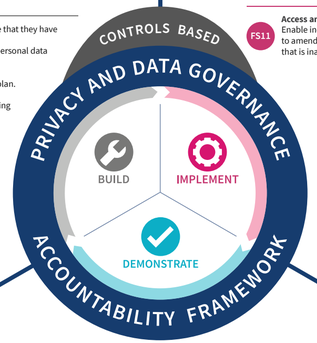
FS6 **Awareness and Training**
Communicate expectations. Provide general and contextual training.

24 Core Controls

- 1.1 Identify internal stakeholders. Establish program leadership and governance. Define program mission, vision, and goals.
- 1.2 Appoint a CPO, DPO, or other Privacy Leader.
- 1.3 Identify, assess, and classify data-related strategic, operational, legal, compliance, and financial risks.
  - 1.3.1 Define objective criteria for assessing risks to individuals, the data, and the organization.
  - 1.3.2 Complete a program-level risk assessment and develop privacy program priorities and an implementation plan aligned to the outcomes of that assessment.
  - 1.3.3 Ensure that Privacy by Design (PbD) is based on an inherent risk analysis and incorporates appropriate controls for mitigating such risks.
  - 1.3.4 Develop data security program priorities and an implementation plan aligned to the outcomes of the program-level risk assessment.
  - 1.3.5 Where planned data processing presents a high inherent risk of harm to individuals based on objective criteria for assessing risks to individuals, ensure that privacy impact assessments address existing and potential risks identified in the organization by evaluating the effectiveness of controls mitigating such risks.
- 1.4 Allocate appropriate resources to support the defined mission and vision, and to manage identified risks.
  - 1.4.1 Establish and maintain budgets for privacy program.
  - 1.4.2 Define privacy-related roles and responsibilities. Assign competent personnel and support their development.
- 1.5 Develop policies, procedures, and guidelines to define and deploy effective and sustainable governance and controls for managing data-related risks.
  - 1.5.1 Ensure the scope of policies, procedures, and guidelines is clearly defined.
  - 1.5.2 Document and communicate updates to policies, procedures, and guidelines.
  - 1.5.3 Ensure that policies and standards are enforceable.
- 1.6 Establish, manage, measure, and continually improve processes for evaluating third parties to ensure that they have appropriate privacy and data protection safeguards in place.
- 1.7 Establish, manage, measure, and continually improve processes for implementing and maintaining personal data processing inventory with data classification built in.
- 1.8 Establish, manage, measure, and continually improve processes for developing, implementing, and periodically testing the effectiveness of a personal data incident management and breach response plan.
- 1.9 Establish, manage, measure, and continually improve processes for assessing the inherent data processing risk for new, ongoing, and modified data processing based on objective criteria for assessing risks to individuals.
  - 1.9.1 Establish, manage, measure, and continually improve processes for completing privacy impact assessments (PIAs) to evaluate the effectiveness of controls mitigating such risks.
  - 1.9.2 Establish, manage, measure, and continually improve processes for implementing all necessary controls to mitigate risk to appropriate levels.
- 1.10 Establish, manage, measure, and continually improve processes for establishing, implementing, publicizing, and actively managing a privacy complaint-handling process, including alternative dispute resolution as needed.
- 1.11 Establish, manage, measure, and continually improve processes for establishing, implementing, and actively managing processes to honor individual rights such as access, correction, deletion, and data portability.
- 1.12 Communicate about the value and risks associated with data as well as program and process expectations. Provide both general and contextual training, including professional certification training. Reinforce messages periodically.

TrustArc

NYMITY



IMPLEMENT

Define data needs, identify data processing risks, ensure the data processing is lawful, manage data flows and third parties, address individual rights, provide data security, data quality, and transparency.

8 Standards

FS7 **Data Necessity**
Optimize data value by collecting and retaining only the data necessary for strategic goals. Leverage anonymization, de-identification, pseudonymization, and coding to mitigate data storage-related risks.

FS8 **Use, Retention, and Disposal**
Ensure data is used only as legally permissible and solely for purposes that are relevant to and compatible with the purposes for which it was collected.

FS9 **Disclosure to Third Parties and Onward Transfer**
Preserve the framework standards and protections for data when it is transferred to third-party organizations and/or across country borders.

FS10 **Choice and Consent**
Enable individuals to choose whether personal data about them is processed. Obtain and document prior permission where necessary and appropriate, and enable individual to optout of ongoing processing.

FS11 **Access and Individual Rights**
Enable individuals to access information about themselves, to amend, correct, and as appropriate, delete information that is inaccurate, incomplete, or outdated.

FS12 **Data Integrity and Quality**
Assure that data is kept sufficiently accurate, complete, relevant, and current consistent with its intended use.

FS13 **Security**
Protect data from loss, misuse, and unauthorized access, disclosure, alteration, or destruction.

FS14 **Transparency**
Inform individuals about the ways in which data about them are processed and how to exercise their data-related rights.

24 Core Controls

- 2.1 Optimize data value by collecting and retaining only the data necessary for strategic goals. Leverage anonymization, de-identification, pseudonymization, and coding to mitigate data storage-related risks.
- 2.2 Ensure data is used solely for purposes that are relevant to and compatible with the purposes for which it was collected.
- 2.3 Keep data in identifiable form only as long as necessary for identified processing purposes of which individuals have been informed. If data are needed for a longer period of time for research- or optimization-related purposes, implement coding, pseudonymization, or similar mechanisms to limit the risk to individuals.
- 2.4 Ensure that all data processing is legally permissible, including any data disclosures to third parties.
- 2.5 Define and communicate retention periods for personal data used by the process or technology.
- 2.6 Assess vendors handling personal data for effective safeguards and controls.
- 2.7 Execute appropriate contracts with vendors supporting the process or technology or with any third parties.
- 2.8 Ensure personal data is adequately protected when transferred internationally, including transfers to third parties and vendors.
- 2.9 Enable individuals to choose whether personal data about them is processed. Obtain and document prior permission (consent) where necessary and appropriate, and enable individual to opt-out of ongoing processing.
  - 2.9.1 Ensure consent is clear and conspicuous, freely given, and able to be withdrawn at any time.
  - 2.9.2 Ensure that evidence of consent can be produced at any time.
- 2.10 If the individual is a child (as defined by applicable law), obtain verifiable parental consent for the processing.
- 2.11 Provide mechanisms for individuals to easily opt-out of ongoing processing about them.
- 2.12 Enable individuals to access information about themselves, to amend, correct, and as appropriate, delete information that is inaccurate, incomplete, or outdated.
- 2.13 Enable individuals to rectify inaccurate personal data processed by the technology, process, or activity.
- 2.14 Where appropriate and in accordance with applicable law, enable individuals to delete personal data processed by the technology, process, or activity.
- 2.15 Enable individuals to request reasonable restrictions on uses or disclosures of personal data about them where such restrictions do not adversely affect the rights of others, do not require disproportionate efforts for the organization to implement, or where required by law.
- 2.16 Where reasonable and practicable, enable individuals to access information about themselves in a machine-readable or electronic format consistent with its intended use.
- 2.17 Assure that data are kept sufficiently accurate, complete, relevant, and current consistent with its intended use.
- 2.18 Put in place administrative, physical, and technical safeguards to protect data from loss; misuse; and unauthorized access, disclosure, alteration, or destruction.
- 2.19 Conduct security risk assessments as required by the security program, and remediate areas of identified risk.
- 2.20 Inform individuals about the ways in which data about them are processed and how to exercise their data-related rights, including those arising out of data-related incidents and breaches.
  - 2.20.1 Ensure information about data processing and individuals rights is clear and conspicuous.
  - 2.20.2 Ensure information about data processing and individuals' rights is provided before information is collected from individuals, at the time of collection, or as soon as practicable thereafter.

DEMONSTRATE

Monitor, evaluate, and report on compliance, control effectiveness, risk, and maturity.

2 Standards

FS15 **Monitoring and Assurance**
Evaluate and audit effectiveness of controls and risk-mitigation initiatives.

FS16 **Reporting and Certification**
Demonstrate the effectiveness of your program and controls to management, the Board of Directors, employees, customers, regulators, and the public.

7 Core Controls

- 3.1 Continually monitor and periodically evaluate program maturity, and periodically assess and audit the effectiveness of program controls and risk-mitigation initiatives.
- 3.2 Select and implement mechanisms to demonstrate the effectiveness of your program and controls to management, the Board of Directors, employees, customers, regulators, and the public.
- 3.3 Establish a point of contact for direct cooperation with DPAs.
- 3.4 Consider demonstrating compliance by adhering to binding and enforceable codes of conduct.
- 3.5 Consider demonstrating compliance through certification, seals, and/or marks.
- 3.6 Consider demonstrating corporate data responsibility to customers and the public as part of the organization's corporate social responsibility and/or sustainability goals.
- 3.7 If your organization is a data-driven business, consider demonstrating data stewardship, ethics, and accountability as part of the value of the organizational brand value.

© 2021 TrustArc Inc. All rights reserved.